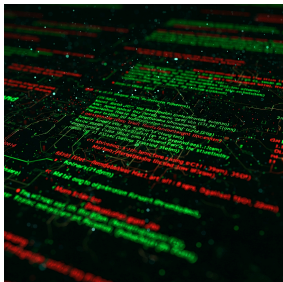


A 2.4.2 Network Vulnerabilities (HL Only)



A 2.4.2 Describe common network vulnerabilities. (HL only)

This section details network vulnerabilities for IB Computer Science HL students. It covers DDoS, insecure protocols, malware, MitM, phishing, SQL injection, XSS, unpatched software, weak authentication and zero-day exploits, offering mitigation techniques and key questions. The ebook aims to provide a comprehensive understanding, aligning with syllabus needs and encouraging critical thinking

Introduction: Navigating the Complex World of Network Security

In today's connected world, network security is **extremely important**.

We depend on digital systems for almost everything - from talking and shopping to school and healthcare. This means protecting these networks from **hackers and other bad actors** is more critical than ever.

For any computer scientist, understanding network security is a **vital (essential) skill**.

The digital world is **always changing**, and new threats appear every day. Because of this, we must keep learning about the latest **vulnerabilities** (weaknesses) and the newest security **methods** (ways to protect things).

Distributed Denial of Service (DDoS)

Description:

A DDoS attack floods a network or server with malicious traffic, overwhelming its resources and making it unavailable to legitimate users.

How it Works:

Attackers use botnets (networks of compromised computers) to send massive amounts of traffic to the target.

Impact: Service disruption, financial losses, reputational damage.

Mitigation

- DDoS mitigation tools.
- Content Delivery Networks (CDNs) to distribute traffic.
- Intrusion Detection and Prevention Systems (IDS/IPS).

Key Questions

What are the main differences between a DoS and a DDoS attack?

How can CDNs help mitigate DDoS attacks?

What are the ethical considerations of using DDoS mitigation services that might filter legitimate traffic?

Insecure Network Protocols

Description:

Using outdated or poorly configured network protocols that lack adequate security measures.

Examples:

- Telnet (unencrypted remote access).
- FTP (unencrypted file transfer).

Impact:

- Data interception
- Credential theft
- Unauthorised access

Mitigation:

- Using encrypted protocols such as SSH (secure shell) for remote access.
- SFTP (secure FTP) or FTPS (FTP secure) for file transfer.
- Transport Layer Security (TLS) for secure communication.

Key Questions:

Why is it important to disable or replace insecure protocols?

What are the key differences between FTP and SFTP?

How does TLS ensure secure communication over a network?

Description

Malicious software is designed to infiltrate and harm computer systems.

Types

Viruses, worms, Trojans, ransomware, spyware, adware.

How it Spreads

- Phishing emails,
- infected websites,
- drive-by downloads,
- infected USB drives.

Impact

- Data theft,
- System corruption
- Financial losses
- Identity theft

Mitigation

- Antivirus software.
- Email filtering solutions.
- Regular software updates.
- User awareness training.

Key Questions

What are the key differences between viruses and worms?

How can phishing emails be identified?

What is the role of user education in preventing malware infections?

Man-in-the-Middle (MitM) Attacks

Description

An attacker intercepts communication between two parties without their knowledge.

How it Works

Attackers position themselves between the client and server, intercepting and potentially modifying data.

Examples

- ARP spoofing
- DNS spoofing
- SSL stripping

Impact

- Data theft
- Credential theft
- Manipulation of data.

Mitigation

- Encrypted protocols such as HTTPS.
- VPNs.
- Strong authentication methods.

Key Questions

How does HTTPS prevent MitM attacks?

What is ARP spoofing, and how does it facilitate MitM attacks?

How do VPNs protect against MitM attacks on public Wi-Fi networks?

Phishing Attacks

Description

Deceptive attempts to acquire sensitive information by disguising as a trustworthy entity.

How it Works

Attackers send fraudulent emails, messages, or websites that mimic legitimate organisations.

Goal

Steal usernames, passwords, credit card details, and other personal information.

Impact

- Financial losses
- Identity theft
- Data breaches.

Mitigation

- Email filtering solutions.
- User awareness training.
- Multi-factor authentication (MFA).

Key Questions

What are the common characteristics of phishing emails?

Why is multi-factor authentication effective against phishing?

How can organisations train employees to identify and avoid phishing attacks?

SQL Injection

Description

An attacker injects malicious SQL code into an application's database queries.

How it Works

Exploits vulnerabilities in web applications that use user-supplied input to construct SQL queries.

Impact

- Data theft
- Data manipulation
- Unauthorised access to the database.

Mitigation

- Input validation (filtering, whitelisting).
- Parameterised queries or prepared statements.

- Principle of least privilege for database access.

Key Questions

What is input validation, and how does it prevent SQL injection?

How do parameterised queries protect against SQL injection?

What are the potential consequences of a successful SQL injection attack?

Cross-Site Scripting (XSS)

Description

An attacker injects malicious scripts into trusted websites.

How it Works

Exploits vulnerabilities in web applications that display user-supplied data without proper sanitisation.

Impact

- Stealing user credentials
- Redirecting users to malicious websites
- Defacing websites.

Mitigation

- Input validation and output encoding.
- Content Security Policies (CSP).
- Regular security testing.

Key Questions

What is the difference between reflected and stored XSS?

How do Content Security Policies (CSPs) mitigate XSS attacks?

What are the potential consequences of a successful XSS attack?

Unpatched Software

Description

Failure to install security updates and patches for operating systems and applications.

How it Works

Attackers exploit known vulnerabilities in outdated software.

Impact

- System compromise
- Data breaches
- Malware infections.

Mitigation

- Automated patch management systems.
- Regular security audits.
- Keeping software up to date.

Key Questions

Why is it important to install security updates promptly?

What are the risks of running unpatched software?

How can organisations automate the patch management process?

Weak Authentication

—

Description

Using easily guessable passwords, default credentials, or lacking multi-factor authentication.

How it Works

Attackers can easily gain unauthorised access to systems and data.

Impact

- Data breaches
- System compromise
- Identity theft.

Mitigation

- Complex password policies.
- Multi-factor authentication (MFA).
- Account lockout policies.

Key Questions

What are the characteristics of a strong password?

How does multi-factor authentication enhance security?

What are the best practices for managing user accounts and passwords?

Zero-Day Exploits

Description

Attacks that exploit previously unknown vulnerabilities in software.

How it Works

Attackers discover and exploit vulnerabilities before developers can release a patch.

Impact

- System compromise
- Data breaches
- Widespread infections.

Mitigation

- Intrusion Detection and Prevention Systems (IDS/IPS).
- Sandboxing and application isolation.
- Behavioural analysis and anomaly detection.

• Key Questions

Why are zero-day exploits particularly dangerous?

How can behavioural analysis help detect zero-day exploits?

What proactive measures can organisations take to protect against zero-day attacks?



Key Ideas in Network Security

- **Be proactive, not reactive.** You must act *before* an attack happens, not just clean up afterward.
- **Use layered security.** Don't rely on only one defense. Use many layers (like firewalls and splitting up your network) so if one fails, others still protect you.
- **Know your weaknesses.** Understand common attacks like **phishing** (fake emails to steal passwords) and **DDoS** (overloading your system) so you can build defenses against them.
- **Watch your network 24/7.** Continuous monitoring helps you spot attacks or problems as soon as they start.
- **Test your system regularly.** Conduct security checks (assessments) to find and fix weaknesses before criminals do.
- **Keep learning.** New threats appear daily. You must always learn about new dangers and new ways to protect your data.
- **Train your people.** Human error is a major cause of security breaches. Teaching users how to spot scams is essential.
- **Security is a process, not a product.** It's a non-stop job that always needs attention and updates.

A 2.4.2 Quiz

Test your knowledge in this quiz.

1

What is a Distributed Denial of Service (DDoS) attack?

- A. ☐ An attack that targets a single computer.
- B. ☒ An attack that floods a network with malicious traffic.
- C. ☐ An attack that steals user credentials.
- D. ☐ An attack that exploits unpatched software.

2

Which of the following is an example of an insecure network protocol?

- A. ☐ SSH

B. ☒ Telnet

C. ☐ SFTP

D. ☐ HTTPS

3

How does malware typically spread?

A. ☐ Through physical contact.

B. ☐ Through government surveillance programs.

C. ☒ Through phishing emails and infected websites.

D. ☐ Through telepathic communication.

4

What is the goal of a Man-in-the-Middle (MitM) attack?

A. ☐ To install ransomware on a victim's computer.

B. ☒ To intercept and potentially modify communication between two parties.

C. ☐ To deface a website.

D. ☐ To crash a server.

5

What is a key characteristic of a phishing email?

A. ☐ It never includes attachments.

B. ☐ It always contains grammatical errors.

C. ☐ It is always sent from a suspicious email address.

D. ☐ It often impersonates a trustworthy entity.

6

How does SQL injection work?

A. ☐ By exploiting vulnerabilities in web applications that handle user input.

B. ☐ By sending malicious traffic to a server.

C. ☐ By using social engineering tactics to trick users.

D. ☐ By installing a keylogger on a victim's computer.

7

What is the potential impact of Cross-Site Scripting (XSS)?

A. ☐ Denial of service.

B. ☐ System updates.

C. ☐ Stealing user credentials and redirecting users to malicious websites

D. ☐ Data encryption.

8

Why are unpatched software vulnerabilities a security risk?

A. ☐ They allow attackers to exploit known weaknesses.

B. ☐ They improve the performance of the software.

C. ☐ They make the software more user-friendly.

D. ☐ They enhance the security of the software.

9

What is a mitigation strategy for weak authentication?

- A. ☐ Using the same password for all accounts.
- B. ☐ Disabling account lockout policies.
- C. ☐ Sharing passwords with colleagues.
- D. ☒ Implementing multi-factor authentication.

10

Why are zero-day exploits particularly dangerous?

- A. ☐ They are easy to detect
- B. ☐ They are widely known and publicized.
- C. ☐ They are only used by ethical hackers.
- D. ☒ They exploit vulnerabilities that are unknown to the software vendor.

All materials on this website are for the exclusive use of teachers and students at subscribing schools for the period of their subscription. Any unauthorised copying or posting of materials on other websites is an infringement of our copyright and could result in your account being blocked and legal action being taken against you.

 **Report a problem**